UNC5537 Snowflake Attacks

Cloud Security Breach Analysis

Adarsh Rai | adarshr@andrew.cmu.edu

Heinz College of Information Systems, Carnegie Mellon University

95746-B: Cloud Security

Professor George Werbacher

October 11, 2025

Introduction

Cloud adoption across industries has accelerated the movement of sensitive workloads to public infrastructure and Software-as-a-Service (SaaS) platforms. This transition has redistributed risk across providers and customers, making identity assurance and configuration management central to enterprise security. In May 2024, the threat actor cluster **UNC5537** conducted a coordinated campaign targeting customer accounts of **Snowflake Inc.**, a leading cloud-native data warehousing service. Using credentials previously harvested by infostealer malware, the actors authenticated to Snowflake tenants that had not enforced multifactor authentication (MFA), executed legitimate SQL queries, and exfiltrated large volumes of data later offered for sale and extortion.

The incident did not compromise Snowflake's underlying infrastructure; instead, it demonstrated how the exploitation of valid credentials can bypass traditional perimeter and infrastructure defenses within a SaaS environment. This distinction underscores the importance of clearly defined security ownership under the **Shared Responsibility Model**. The following analysis reconstructs the UNC5537 attack chain, examines the safeguards that failed, and assesses where provider-to-customer boundaries contributed to the exposure. It integrates **Bell-Lapadula** and **Clark-Wilson** models to evaluate confidentiality and integrity failures, correlating them with observable technical controls. The objective is to translate the lessons from this breach into verifiable security recommendations and a modified shared responsibility framework applicable to high-value SaaS data platforms.

Incident Context and Impact Assessment

Organizational Background and Cloud Environment Configuration

Snowflake Inc. operates as a cloud-native data warehousing platform built on top of Amazon Web Services (AWS), Microsoft Azure, and Google Cloud Platform (GCP) infrastructure. The service delivers elastic compute and storage through a multi-tenant architecture that separates control and data planes, allowing customers to scale resources independently. Customers authenticate through Snowflake's Identity and Access Management (IAM) layer, typically integrated with enterprise identity providers via Security Assertion Markup Language (SAML) or OAuth 2.0. Access policies can be supplemented with network policies, role-based access controls (RBAC), and optional multifactor authentication (MFA).

In practice, MFA enforcement within Snowflake was configurable at the customer level and not enabled by default for legacy accounts [1]. This configuration flexibility, while advantageous for deployment, created heterogeneous security postures across tenants. Many customer accounts, including several belonging to Fortune 500 organizations, relied solely on username–password authentication stored in enterprise password vaults or reused across environments.

Chronological Reconstruction of the Incident

Between April and June 2024, Mandiant (a Google Cloud company) observed a coordinated intrusion campaign attributed to UNC5537, a financially motivated actor cluster [1]. The group leveraged credentials previously obtained by infostealer malware families such as Vidar, Raccoon Stealer, and Redline Stealer distributed through malicious websites and cracked software bundles. These credential dumps, later sold on underground markets, contained valid Snowflake usernames and passwords associated with corporate email domains.

The campaign unfolded in four discrete phases:

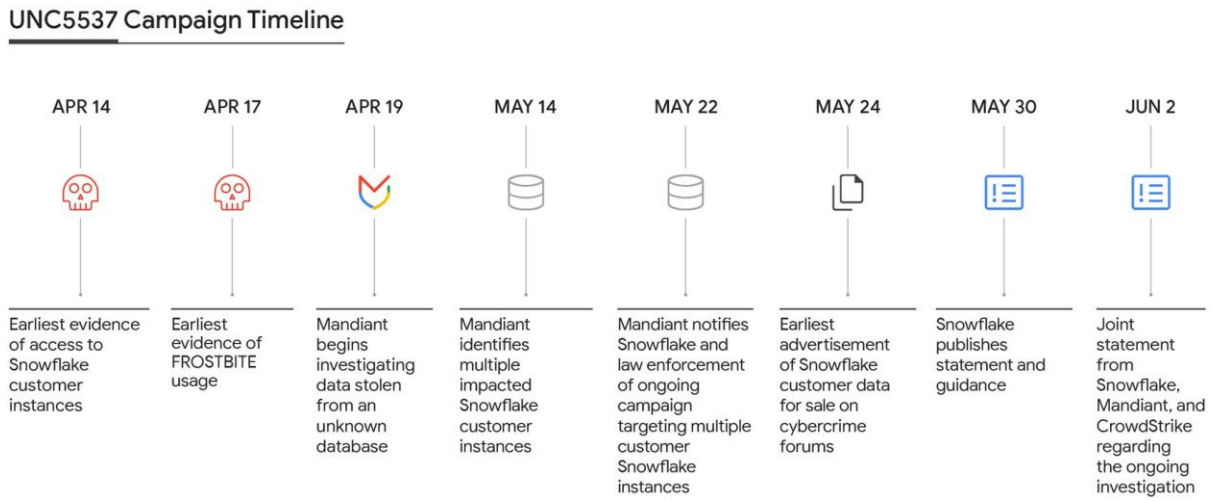
Credential Acquisition: Harvesting of authentication data by commodity malware across unmanaged or personal endpoints used by employees.

Account Validation: Programmatic testing of credentials against Snowflake login endpoints, focusing on tenants without enforced MFA.

Session Establishment and Reconnaissance: Successful logins created authenticated sessions in legitimate Snowflake web consoles or clients. Attackers enumerated databases, views, and external stages through standard SQL SHOW and DESCRIBE commands.

Data Exfiltration and Monetization: Selected datasets were exported using standard COPY INTO <external_stage> statements or downloaded through web interfaces, followed by extortion attempts and public sale via the ShinyHunters network [2], [3].

At each transition point, a security control existed that, if enforced, could have prevented escalation. Specifically, mandatory MFA, anomaly detection for new geo-locations, and rate-limit policies on bulk exports were absent or inconsistently implemented.



Multidimensional Impact Analysis

Financial Impact

While Snowflake confirmed its core service remained uncompromised, customers incurred substantial investigation and containment costs, including third-party forensics, user credential resets, and legal notifications. Analysts estimated direct costs in the tens of millions of dollars across affected organizations when including regulatory fines and brand-damage mitigation [3].

Operational Impact

Many enterprises temporarily suspended data warehouse connections to isolate compromised tenants, interrupting downstream analytics, reporting, and AI workflows dependent on Snowflake's APIs. For service-sector customers, such downtime had measurable revenue impact.

Reputational Impact

Although Snowflake's transparency limited misinformation, public association with breaches at recognizable brands such as Ticketmaster and Santander amplified reputational damage. Trust erosion was further compounded by the perception that SaaS providers were responsible for "end-to-end" protection, exposing confusion around the shared-responsibility boundary [4].

Evaluation of Public Disclosure and Response Effectiveness

Snowflake issued its first advisory on 31 May 2024, emphasizing that no breach of the core platform had occurred and attributing incidents to the misuse of stolen credentials [2]. CISA simultaneously released AA24-152A, recommending all customers enable MFA, rotate credentials, and monitor unusual query patterns [5]. Mandiant followed with an incident-response report containing hunting queries and Indicators of Compromise (IoCs).

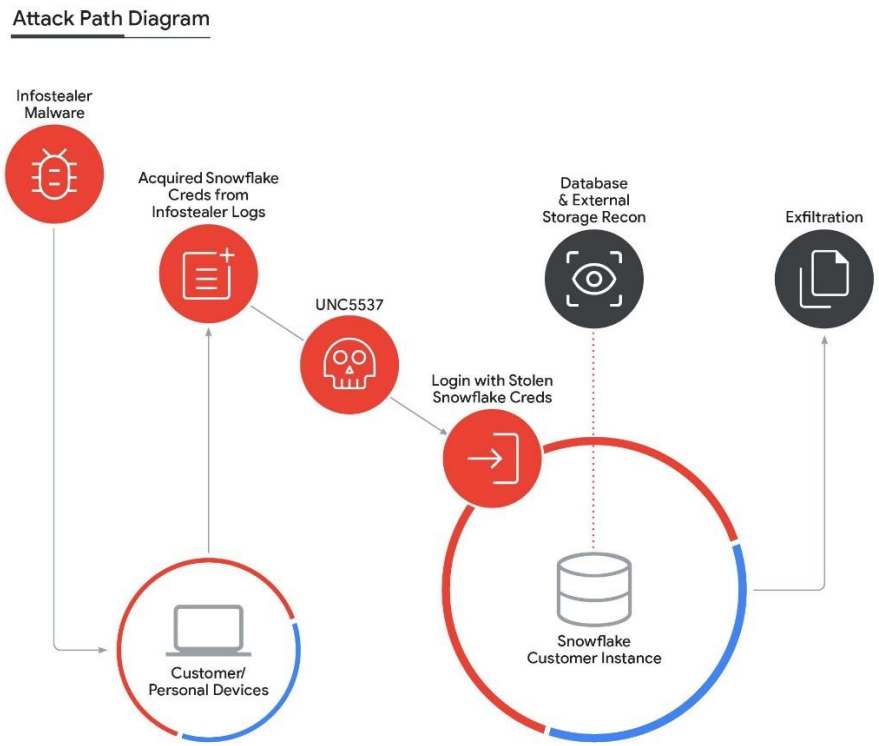
The disclosure process was broadly effective in technical accuracy and speed; however, customers criticized the lack of earlier enforcement of MFA and absence of provider-side alerts for high-volume data exports. Communication from Snowflake improved during June as it introduced mandatory MFA for new accounts and initiated phased deprecation of password-only logins. The coordinated messaging among Snowflake, Mandiant, and CISA helped clarify scope, though discrepancies in victim-count reporting (≈165 potential vs. ≈100 confirmed tenants) demonstrated limitations in centralized visibility [3], [5].

Technical Vulnerability Analysis

Attack Vectors and Exploitation Techniques

The UNC5537 campaign exploited a narrow but high-impact vulnerability surface: customer accounts on Snowflake that lacked enforced multifactor authentication (MFA). The attack chain followed a credential-reuse and session-abuse pattern observed across multiple cloud services. Stolen credentials were originally harvested through infostealer malware such as Raccoon Stealer, RedLine, and Vidar, which exfiltrated browser-stored passwords and cookies from unmanaged endpoints [1]. These datasets, widely

available on illicit forums and marketplaces, contained valid Snowflake usernames and passwords tied to enterprise domains [2].



[1]

Once validated, the threat actors authenticated directly to Snowflake's login endpoint and established legitimate sessions using browser automation or API-based connections, bypassing intrusion-detection mechanisms that monitor for exploit signatures rather than credential-based access [3]. Within authenticated sessions, standard SQL commands such as SHOW DATABASES and DESCRIBE STAGE were used for reconnaissance, followed by COPY INTO <external_stage> to export datasets to attacker-controlled cloud storage [4]. These operations blended seamlessly with legitimate administrative activity, complicating anomaly detection.

Failed and Bypassed Safeguards

Lack of Enforced MFA and Conditional Access

Snowflake documentation listed MFA as a recommended rather than mandatory feature before June 2024 [5]. Many legacy tenants had not migrated to new identity federation configurations. The absence of platform-level enforcement permitted valid logins with only username and password credentials. Conditional access controls (e.g., geolocation checks, device trust, or IP allowlisting) were available but not uniformly implemented across tenants.

Excessive Privilege and Broad Role Assignments

In several affected accounts, service roles such as ACCOUNTADMIN retained unrestricted read and export privileges. Fine-grained RBAC and attribute-based access controls (ABAC) were either unconfigured or applied inconsistently [6]. As a result, once authenticated, attackers inherited near-global access without triggering privilege-escalation alerts.

Ineffective Anomaly Detection and Egress Monitoring

Although Snowflake offers native telemetry through the ACCOUNT_USAGE schema and integration with security information and event management (SIEM) tools, many customers had not configured automated anomaly detection for large query results or abnormal network egress. This visibility gap allowed bulk data exports to proceed undetected. The lack of guardrails for outbound transfers from Snowflake to external cloud storage represented a critical blind spot in customer implementations [7].

Delayed Response to Infostealer Ecosystem

Credential dumps linked to the campaign had been circulating since at least 2023 [1]. Customers lacked proactive checks against known compromised credentials or integration with threat-intelligence feeds capable of identifying reused usernames. This oversight demonstrates a failure in identity hygiene, a foundational element of cloud security posture management (CSPM).

Control Failures Matrix

Safeguard / Control	Availability (Platform)	Implementation (Tenants)	Effect if Enforced
Multifactor Authentication (MFA)	Optional (pre-June 2024)	Partially adopted; legacy accounts unenforced	Prevented unauthorized logins with stolen credentials
Identity Federation / SSO	Supported via SAML / OAuth	Inconsistent integration across orgs	Centralized auth and MFA inheritance across corporate tenants
RBAC / Least Privilege Roles	Fully available	Over-permissive default roles (*ACCOUNTADMIN*)	Restricted access to sensitive datasets and limited lateral movement
Conditional Access / Geo-IP Checks	Configurable through policies	Rarely enabled outside regulated sectors	Blocked logins from unfamiliar devices or regions
Egress Alerts / Rate Limits	Configurable through ACCOUNT_USAGE and network policies	Rarely implemented or monitored	Detected and contained bulk data exports to external stages

Safeguard / Control	Availability (Platform)	Implementation (Tenants)	Effect if Enforced
Anomaly Detection / SIEM Integration	Supported via API telemetry	Limited adoption by small tenants	Flagged unusual query volumes and behavior deviation

Counterfactual Controls and Cost Evaluation

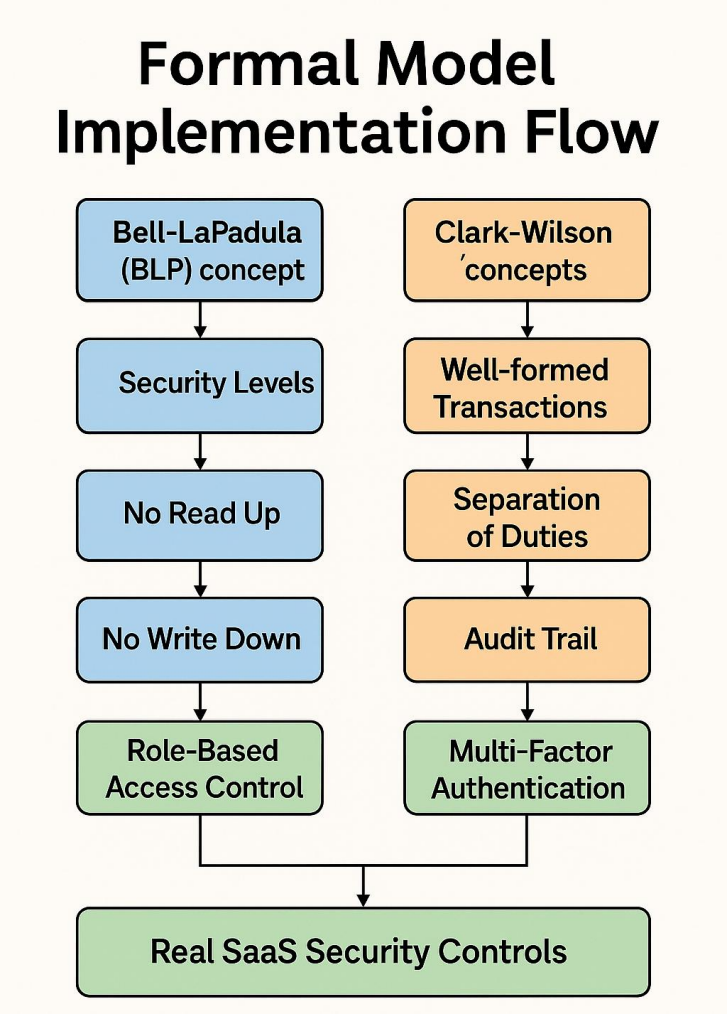
Had MFA been mandatory for all Snowflake accounts, the attack vector would have been nullified, as none of the compromised credentials included secondary authentication factors [5]. The cost to implement and enforce MFA for all Snowflake tenants, largely administrative and training overhead, would have been substantially lower than the aggregate cost of post-breach response, which analysts estimate exceeded USD 25 million across customer organizations when accounting for forensics, downtime, and regulatory penalties [3].

Implementing adaptive access policies, Just-In-Time (JIT) role elevation, and rate-limited data exports would have reduced potential exposure with negligible impact on system performance. These preventive measures represent a fraction of the financial and reputational costs generated by the breach. The disparity underscores the classic economic imbalance between proactive and reactive cloud security spending [8].

Application of Formal Security Models

Applying the Bell–LaPadula (BLP) model frames the breach as a violation of the simple-security property: unverified or weakly authenticated subjects (users) gained read access to objects (datasets) classified above their assured clearance level. Had Snowflake enforced strict identity assurance before granting read operations, analogous to requiring subject clearance checks, the confidentiality compromise would not have occurred.

Using the Clark–Wilson model provides an integrity-centric interpretation. Sensitive customer data (Constrained Data Items) was accessed outside of Certified Transactions (TPs) such as authorized ETL pipelines. Enforcing well-formed transactions and Separation of Duties (SoD) between data-access and data-export roles could have prevented large-scale exfiltration. This mapping highlights how theoretical models remain relevant to modern cloud contexts when translated into practical enforcement mechanisms like MFA, scoped service accounts, and audit logging [9].



Comparative Analysis with Similar SaaS Incidents

Credential-based compromises are a recurring pattern across SaaS environments. The Okta Support System breach (2023) similarly involved session-token theft and credential misuse to access customer files [10]. Likewise, the Sisense analytics platform breach (2024) revealed parallel deficiencies in credential hygiene and API key exposure [11]. In each case, the root cause centered on weak authentication and inconsistent implementation of least-privilege principles rather than systemic provider exploitation.

Comparative review reveals three consistent failure modes:

1. Optional or poorly enforced MFA controls at the SaaS layer.
2. Overreliance on customers to configure identity federation securely.
3. Insufficient provider visibility into tenant-specific abnormal data access.

These parallels confirm that credential-abuse attacks represent not isolated failures but systemic challenges in shared-responsibility execution for SaaS products.

Shared Responsibility Model Evaluation

Visual Mapping of Responsibilities Between Provider and Customer

Snowflake operates under a Software-as-a-Service (SaaS) model layered on IaaS resources provided by Amazon Web Services (AWS), Microsoft Azure, and Google Cloud Platform (GCP). Security ownership follows a vertical split:

- Provider responsibilities encompass platform architecture, encryption at rest and in transit, patching, and infrastructure monitoring.
- Customer responsibilities include account authentication, role management, data classification, and network policy configuration [1].

The UNC5537 campaign exposed ambiguity in these boundaries. Customers assumed that Snowflake's default configuration enforced MFA, whereas Snowflake's documentation stated that MFA was optional unless federated through a corporate identity provider [2]. This misalignment resulted in a "responsibility vacuum," where neither side enforced critical authentication controls.

Boundary Misalignments and Contributing Factors

Identity and Access Management (IAM)

While Snowflake provided mechanisms for SSO and MFA integration, it did not require them by default. Customers interpreted these controls as provider-enforced safeguards rather than configurable options. The absence of centralized enforcement created heterogeneous tenant security baselines [3].

Data Governance and Access Control

Over-permissive roles such as ACCOUNTADMIN remained active in many environments, granting attackers lateral read access once credentials were validated. Provider documentation recommended, but did not automate role scoping or token expiration, leaving governance largely to customer discretion [4].

Egress and Network Controls

Outbound data transfer to external stages (e.g., S3 buckets) lacked provider-side rate-limit or anomaly-based blocking. Snowflake's architecture allowed unrestricted data copy operations when executed by authenticated principals. Customers, assuming internal controls existed, seldom implemented external DLP or egress-filtering policies [5].

Monitoring and Logging Visibility

Log visibility for SaaS customers was reactive rather than continuous. ACCOUNT_USAGE and LOGIN_HISTORY tables provided historical records but not real-time alerting. Without direct API-level telemetry, customers were unable to detect exfiltration events until after forensic notification [6].

Documentation and Communication Evaluation

Prior to May 2024, Snowflake's Shared Responsibility Model (SRM) documentation emphasized the division between "security of the cloud" (provider) and "security in the cloud" (customer), mirroring AWS and Azure guidance [7], [8]. However, unlike IaaS or PaaS offerings, SaaS models require greater provider default enforcement. The SRM lacked explicit language designating MFA, network policies, or egress limits as baseline provider obligations.

Following the incident, Snowflake revised its documentation to state that MFA would become mandatory for all new accounts and began phasing out password-only authentication [2]. This update aligns with the evolving "shared-fate" philosophy described by Google Cloud, which advocates proactive provider participation in tenant security outcomes [9].

Communication during the disclosure period was generally transparent but initially fragmented. Early advisories emphasized customer misconfigurations without clarifying the provider's forthcoming control changes, leading to perceptions of blame shifting. Coordination among Snowflake, Mandiant, and CISA improved mid-June, producing consistent guidance and shared hunting queries [1], [5].

Post-Incident Response and Lessons Through the SRM Lens

Snowflake's post-incident actions demonstrated movement from passive delineation to active enforcement within the SRM framework. The company introduced mandatory MFA, enhanced anomaly-detection capabilities, and a customer security health dashboard providing alerts for weak configurations [2]. These initiatives realigned accountability closer to the "shared-fate" model, acknowledging that provider defaults directly influence tenant exposure.

From the customer perspective, the incident catalyzed reevaluation of federated SSO configurations, credential rotation policies, and continuous-monitoring integrations with SIEM platforms. Many

organizations adopted threat-intelligence ingestion to identify compromised user credentials in infostealer marketplaces, a practice not previously embedded in SaaS security operations [3].

Collectively, the response reframed shared responsibility as a continuum rather than a boundary: provider enforcement, customer configuration, and third-party integration must coexist to maintain confidentiality and integrity in multi-tenant SaaS environments.

Theoretical Framework and Recommendations

Modified Shared Responsibility Framework for SaaS Data Platforms

The UNC5537 campaign demonstrates that SaaS platforms require a more prescriptive shared responsibility model, one that accounts for overlapping accountability zones and varying tenant maturity. Traditional delineations ("provider secures the cloud, customer secures data in the cloud") fail in multi-tenant SaaS contexts where provider defaults shape customer exposure [1].

A Modified SaaS Shared Responsibility Framework is proposed, consisting of three layers:

Provider-enforced controls
Mandatory MFA for all user and service accounts, default least-privilege role templates, automated egress rate-limits, and proactive credential compromise monitoring through integrated threat intelligence.

Customer-managed controls
Enforcement of identity federation, periodic credential rotation, classification-based access policies, and SIEM integration for anomaly alerts.

Collaborative oversight
Shared analytics dashboards, continuous configuration scoring, and incident-response coordination channels between provider and customer SOC teams [2].

This approach aligns with the "shared fate" model articulated by Google Cloud, showing cooperative outcomes rather than static boundaries [3].

Technical and Governance Recommendations

Identity and Access Management (IAM)

Implement phishing-resistant MFA (FIDO2/WebAuthn) for all Snowflake and federated accounts. Enforce JIT (Just-in-Time) role elevation and session timeouts to limit exposure. Provider platforms should integrate credential compromise APIs that automatically invalidate credentials found in infostealer datasets [4].

Data Governance and Access Control
Customers should adopt attribute-based access control (ABAC) and align data classification with Snowflake roles. Default privileges for system roles (e.g., ACCOUNTADMIN) should be scoped to non-sensitive resources unless explicitly justified [5].

Egress and Monitoring Controls
Provider-managed rate-limits on large COPY INTO operations, coupled with customer-defined DLP policies, can prevent bulk data exports. Centralized egress telemetry APIs should surface real-time visibility into destination endpoints.

Governance and Vendor Oversight
Institutions using Snowflake or similar SaaS environments should establish vendor risk-assessment checklists based on NIST SP 800-161 and ISO 27036 for periodic verification of provider control maturity [6]. Contracts should explicitly reference the provider's SRM obligations, escalation procedures, and notification timeframes for credential compromise events.

Formal Verification and Policy-as-Code Implementation
The Bell–LaPadula model can be operationalized in SaaS by embedding clearance enforcement into policy engines, formally verifying that "no read operation occurs without strong identity validation." Corresponding Rego (OPA) rules might assert that data queries tagged as Confidential require authenticated sessions with MFA and trusted device claims.

Similarly, the Clark–Wilson model supports verifiable data integrity controls. By constraining bulk exports to certified transactions (TPs), defined pipelines or ETL processes, and validating each through Integrity Verification Procedures (IVPs), customers and providers can test that only authorized subjects execute these TPs [7]. Continuous evaluation of these policies through automated compliance checks aligns with ISO 27001:2022 and NIST SP 800-53 CA-7 control families for continuous monitoring [8].

Residual Risk and Compensating Controls

Despite improved architecture and verification, residual risks persist. Token replay attacks, insider misuse, and third-party integration leakage remain possible due to complex cloud ecosystems.

Compensating controls include:

- Short-lived session tokens and ephemeral credentials for service accounts.
- Just-in-Time (JIT) provisioning for privileged roles.
- Honeypot tables or canary datasets to detect illicit queries or exports.
- Continuous cloud posture monitoring (CSPM) integrating anomaly scoring from Snowflake's telemetry with enterprise SIEM systems.

While these measures impose marginal administrative cost, they drastically reduce the mean time to detect (MTTD) and mean time to respond (MTTR), improving resilience without significantly increasing operational complexity [9].

Conclusion

The 2024 Snowflake customer account attacks conducted by UNC5537 underscore how credential-based compromises continue to outpace conventional cloud defenses. The campaign did not exploit a software flaw but rather systemic weaknesses in identity assurance, configuration management, and the shared responsibility boundary between provider and customer. Weak MFA enforcement, excessive role privileges, and limited egress monitoring collectively enabled valid-credential abuse that bypassed traditional security instrumentation. The breach highlights a recurring trend across SaaS ecosystems where user misconfiguration converges with provider leniency in enforcing baseline safeguards.

The analysis demonstrates that theoretical security models such as Bell–LaPadula and Clark–Wilson remain highly applicable to modern cloud contexts when translated into verifiable controls. Bell–LaPadula's confidentiality principles reinforce the need for strong identity proof before granting data access, while Clark–Wilson's integrity model validates the necessity of well-formed transactions, separation of duties, and continuous audit trails. Together, these frameworks provide a formal structure for assessing control gaps and defining measurable enforcement conditions in SaaS environments.

Snowflake's post-incident actions, mandatory MFA, enhanced anomaly detection, and continuous configuration scoring, represent progress toward a shared-fate paradigm in which providers and customers jointly bear operational accountability. Moving forward, SaaS platforms should operationalize shared responsibility through policy-as-code, adaptive telemetry, and verified compliance metrics. For enterprises, investment in credential hygiene, data-classification governance, and proactive monitoring will remain essential. The broader implication is clear: in a cloud ecosystem defined by interdependence, effective security cannot be divided by contractual boundaries, it must be shared, enforced, and continuously validated.

References

[1] "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion," Mandiant / Google Cloud Blog, June 10, 2024. [Online]. Available: https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion Google Cloud
[2] "What we know about the Snowflake customer attacks," *Cybersecurity Dive*, June 2024. [Online]. Available: https://www.cybersecuritydive.com/news/snowflake-customer-attacks-what-we-know/719056/ Cybersecurity Dive
[3] "Mandiant's Analysis Unveils Cause of Snowflake Data Theft," *CyberMagazine*, June 2024. [Online]. Available: https://cybermagazine.com/articles/mandiants-analysis-unveils-cause-of-snowflake-data-theft Cyber Magazine
[4] "Stolen Credentials Fuel Snowflake Data Breaches: Lessons Learned," *Infosecurity Europe*, Aug. 2024. [Online]. Available: https://www.infosecurityeurope.com/en-gb/blog/threat-vectors/snowflake-data-breaches-lessons-learned.html Infosecurity Europe
[5] "Unpacking the 2024 Snowflake Data Breach," *Cloud Security Alliance*, May 2025. [Online]. Available: https://cloudsecurityalliance.org/blog/2025/05/07/unpacking-the-2024-snowflake-data-breach Cloud Security Alliance
[6] "Snowflake Account Attacks Driven by Exposed Legitimate Credentials," *DarkReading*, July 2024. [Online]. Available: https://www.darkreading.com/threat-intelligence/snowflake-account-attacks-driven-by-exposed-legitimate-credentials Dark Reading
[7] "Snowflake Customers Attacked in Ongoing Extortion Campaign," *HIPAA Journal*, June 2024. [Online]. Available: https://www.hipaajournal.com/snowflake-customers-attacked-in-ongoing-extortion-campaign/ The HIPAA Journal
[8] "Over 165 Snowflake customers didn't use MFA, says Mandiant," *The Register*, June 2024. [Online]. Available: https://www.theregister.com/2024/06/11/crims_targeting_snowflake_customers/ The Register
[9] "Mandiant: 'Exposed credentials' led to Snowflake attacks," *TechTarget / Dark Reading*, June 2024. [Online]. Available: https://www.techtarget.com/searchsecurity/news/366588655/Mandiant-Exposed-credentials-led-to-Snowflake-attacks TechTarget
[10] "Inside the Snowflake Breach," SilentBreach Blog, 2024. [Online]. Available: https://silentbreach.com/BlogArticles/inside-the-snowflake-breach/ Silent Breach

Academic / Model References

[11] D. E. Bell and L. J. LaPadula, *Secure Computer Systems: Mathematical Foundations*, MITRE (or publisher), 1973.
[12] D. D. Clark and D. R. Wilson, "A Comparison of Commercial and Military Computer Security Policies," *Proceedings of the IEEE Symposium on Security and Privacy*, 1987.
[13] Brewer & Nash, "The Chinese Wall Security Policy," *Proceedings of the IEEE Symposium on Security and Privacy*, 1989.

Standards / Controls

[14] National Institute of Standards and Technology (NIST), *SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations*, 2020.
[15] NIST, *SP 800-137: Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations*, 2020.
[16] NIST, *SP 800-161 Rev. 1: Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*, 2022.